

O que realmente está exposto?

Na A01, aprendemos a não confundir correlação com causa. Agora o servidor entrega um arquivo interno: precisamos ligar a evidência ao ativo, à fraqueza e à consequência antes de priorizar a resposta.

O código 200 prova entrega; ainda não explica alcance, intenção ou impacto.



**HTTP/1.1
200 OK**

Transformar uma exposição em decisão verificável

Você integra a equipe que revisa a publicação da loja de testes.

RESTRIÇÃO

Somente o Juice Shop local fornecido.

INVESTIGAÇÃO

**Uma requisição por vez;
sem enumeração.**

ENTREGA

**Inventário + registro +
reteste.**

O que o código 200 permite afirmar?

Registre antes de conhecer a arquitetura.

```
GET /ftp/acquisitions.md  
  
HTTP/1.1 200 OK  
Content-Type: text/markdown
```

REGISTRE

2 observações
1 ativo
1 hipótese
1 lacuna

Inventário começa pela consequência

Um item sem função e proprietário conhecidos não pode ser priorizado com confiança.

ATIVO	FUNÇÃO	CONSEQUÊNCIA
Catálogo/API	vender e consultar	fraude ou parada
Dados fictícios	sustentar pedidos	exposição e confiança
Container	executar a loja	ampliação ou indisponibilidade
Controlador OT	comandar processo	produção e safety

ID.AM: inventariar, manter e priorizar ativos conforme missão e impacto.

Uma cadeia, seis perguntas

Os termos ganham precisão quando ligados à mesma evidência.

ATIVO

o que tem valor?

AMEAÇA

quem ou o que causa dano?

FRAQUEZA

que condição pode originar falhas?

VULNERABILIDADE

qual instância é explorável?

EXPOSIÇÃO

por qual caminho é alcançável?

EXPLOIT

que técnica usa a falha?

CHECKPOINT 2

Qual controle você defenderia?

REMOVER

recurso não deveria ser
servido

AUTORIZAR

papel específico precisa
acessar

MONITORAR

correção imediata é inviável

Declare a premissa e a evidência de reteste.

Preveja antes de abrir a rota

A exploração termina em tratamento e validação.

1

CONFIRMAR

alvo e estado

2

PREVER

recurso e resposta

3

OBSERVAR

requisição única

4

REGISTRAR

causa e impacto

5

VALIDAR

controle e reteste

Produza um ticket que outra equipe possa retestar

A flag não é o produto da atividade.

MISSÃO

Relacione ativo, fraqueza, vetor e impacto; escolha um controle e prove como validá-lo.

ENTREGA

**Inventário priorizado
Evidência interpretada
Controle justificado
Reteste definido**

Sem credenciais ou dados reais

Inventário orienta a prioridade

A terminologia conecta evidência, causa, consequência, ação e validação.

INVENTARIAR

OBSERVAR

EXPLICAR

TRATAR

RETESTAR

Transferência: qual consequência física mudaria sua prioridade em uma HMI?